



SEGURIDAD DE LA INFORMACIÓN

UNIVERSIDAD
POLITÉCNICA
DE MADRID

Parcial #3



Apellidos:	Nombre:
-------------------	----------------

Parte 1 de 2 (6 puntos)

La empresa E-Corp utiliza firmas digitales para garantizar la autenticidad de los correos electrónicos de sus altos cargos. Para ello, cada directivo tiene un certificado digital con su clave pública y su correspondiente clave privada. Los certificados digitales han sido emitidos por la Autoridad de Certificación “E-Corp CA” y los clientes de correo han sido configurados para aceptar certificados firmados por la misma. Para que un correo vaya firmado, debe adjuntar la firma al correo y el certificado con el que se ha firmado. El algoritmo de firma utilizado para los correos es RSA con la función hash *lenmod*. Esta función hash consiste en calcular la longitud del contenido del mensaje (en caracteres incluidos espacios) módulo 65. Darlene Alderson, que pertenece al grupo de hackers *fsociety*, quiere ejecutar un ataque conocido como “fraude del CEO” contra E-Corp y su CEO Philip Price.

El fraude del CEO tiene como objetivo engañar a empleados que tienen acceso a los recursos económicos para que paguen una factura falsa o haga una transferencia desde la cuenta de la compañía a un tercero. Darlene ha conseguido falsificar el campo de origen de los correos electrónicos y procede a enviar el siguiente correo al departamento de finanzas:

De: PhilipPrice@ecorp.com
Para: finance@ecorp.com
Asunto: [URGENTE] Transferencia a proveedor
Mensaje (contenido entre las comillas):
“Debemos transferir inmediatamente 20 millones de \$ a la cuenta US33 2045 5787 3647 0001.
Philip Price
E-Corp CEO”
Longitud del mensaje: 111
Firma del correo: {23}
Certificado: Philip Price, Clave pública: {e=5,n=77}, Certificado autofirmado

- 1- Con los datos ofrecidos en el correo, ¿debería el personal de la sección de finanzas proceder a realizar la transferencia? Justifica tu respuesta. [1 punto]

El certificado está autofirmado por lo que la firma no debería de valer directamente. Además la firma tampoco se verifica de forma apropiada ya que la operación de verificación falla.

- 2- Darlene ha escrito un correo al CEO Philip Price haciéndose pasar por una periodista y ha obtenido la siguiente respuesta:

De: PhilipPrice@ecorp.com
Para: alexlevy@newsmorningshow.com
Asunto: Re: Petición de entrevista
Mensaje (contenido entre las comillas):
"Disculpa Alex pero estoy muy ocupado estos días y no te puedo ofrecer una entrevista.
Philip Price E-Corp CEO"
Longitud del mensaje: 108
Firma del correo: {23}
Certificado: Philip Price, Clave pública: {e=5,n=65}, Firma del certificado

- a) Verifica la firma del correo de Philip Price [1,5 puntos]

Para verificar la firma tenemos que calcular el hash del mensaje que es 108 (número de caracteres incluidos los espacios. Eso módulo 65 es 43. Si hacemos $23^5 \bmod 65$ nos debería dar 43. Se hace la operación y se comprueba que coincide.

- b) ¿Podría Darlene con esta información hacerse pasar por el CEO para realizar con éxito el fraude del CEO? En caso afirmativo explica lo que debería hacer Darlene para conseguir realizar el ataque con éxito [3,5 puntos]

Existen dos opciones. Una de ellas es utilizar la vulnerabilidad en el algoritmo de hashing y así poder reutilizar la firma de Philip en el correo que ha escrito a Darlene. Para ello bastaría con que el mensaje de Darlene sea de un tamaño que haga que el hash del mensaje no cambie. Esto sería cualquier longitud que cuyo resultado sea igual que $108 \bmod 91$ [2,5].

La otra opción es que Darlene sea capaz de firmar certificados como Philip. Para ello tendrá que encontrar su clave privada. Con el tamaño de claves utilizadas en este ejercicio se puede hacer un ataque de factorización de manera simple obteniendo los p y q correspondientes a la clave de Philip Price. p y q valen 13 y 7. De ahí puede sacar $\phi(n)$ que es 72 y sabiendo la clave pública sacar el inverso que es 29 (sería la clave privada) [1 punto]. Con esa clave privada puede ya firmar el mensaje. Para ello primero calcula el hash que es $111 \bmod 91 = 20$ [0,5 puntos]. Ahora ya puede firmar que sería $20^{29} \bmod 91$ resultando en 76 [1 punto].

Una vez tiene la firma lo que debería hacer es mandar el mismo correo si ha roto la clave privada o uno de la longitud apropiada pero adjuntando la firma obtenida y el certificado de Philip obtenido de su correo. [1 punto]

Parte 2 de 2 (3 puntos)

La cadena de certificados ofrecida en la última página ha sido devuelta al iniciar una conexión a la web www.instagram.com. Basándote en la cadena de certificados mostrada y el contenido de cada certificado responde a las siguientes preguntas:

- a) Escribe el nombre común del certificado de la autoridad de certificación intermedia. [0,25 puntos]

Digitcert SHA2 High Assurance...

- b) Escribe el inicio del número de serie del certificado anterior. [0,25 puntos]

04 E1 ...

- c) ¿Qué empresa ha emitido ese certificado? [0,25 puntos]

DigitCert Inc.

- d) Escribe el inicio del número de serie del certificado que se puede utilizar para validar la firma del certificado de la autoridad de certificación raíz [0,25 puntos]

02 AC ...

- e) Explica de forma breve el cometido de la clave pública del certificado devuelto por el servidor web. [1,5 puntos]

Cifrar la conexión entre el navegador y el servidor negociando una clave de un algoritmo simétrico tipo AES.

- f) Los exponentes de las claves públicas en los tres certificados son los mismos ¿Implica esto que las claves privadas de todos los certificados son iguales? Justifica tu respuesta [0,5 puntos]

Aunque los exponentes sean los mismos las claves privadas serán diferentes ya que los módulos de cada uno son diferentes



DigiCert High Assurance EV Root CA

Autoridad de certificación raíz
Caduca: lunes, 10 de noviembre de 2031, 1:00:00 (hora estándar de Europa central)
Este certificado es válido

- Confiar
- Detalles

Nombre del sujeto	
País o región	US
Empresa	DigiCert Inc
Unidad organizativa	www.digicert.com
Nombre común	DigiCert High Assurance EV Root CA
Nombre del emisor	
País o región	US
Empresa	DigiCert Inc
Unidad organizativa	www.digicert.com
Nombre común	DigiCert High Assurance EV Root CA
Número de serie	02 AC 5C 26 6A 0B 40 9B 8F 0B 79 F2 AE 46 25 77
Versión	3
Algoritmo de firma	SHA-1 con encriptación RSA (1.2.840.113549.1.1.5)
Parámetros	Ninguno
No válido antes de	viernes, 10 de noviembre de 2006, 1:00:00 (hora estándar de Europa central)
No válido después de	lunes, 10 de noviembre de 2031, 1:00:00 (hora estándar de Europa central)
Información de la clave pública	
Algoritmo	Encriptación RSA (1.2.840.113549.1.1.1)
Parámetros	Ninguno
Clave pública	256 bytes: C6 CC E5 73 E6 FB D4 BB ...
Exponente	65537
Tamaño de la clave	2048 bits
Uso de la clave	Verificar
Firma	256 bytes: 1C 1A 06 97 DC D7 9C 9F ...



DigiCert SHA2 High Assurance Server CA

Autoridad de certificación intermedia
Caduca: domingo, 22 de octubre de 2028, 14:00:00 (hora de verano de Europa central)
Este certificado es válido

- Confiar
- Detalles

Nombre del sujeto	
País o región	US
Empresa	DigiCert Inc
Unidad organizativa	www.digicert.com
Nombre común	DigiCert SHA2 High Assurance Server CA
Nombre del emisor	
País o región	US
Empresa	DigiCert Inc
Unidad organizativa	www.digicert.com
Nombre común	DigiCert High Assurance EV Root CA
Número de serie	04 E1 E7 A4 DC 5C F2 F3 6D C0 2B 42 B8 5D 15 9F
Versión	3
Algoritmo de firma	SHA-256 con encriptación RSA (1.2.840.113549.1.1.11)
Parámetros	Ninguno
No válido antes de	martes, 22 de octubre de 2013, 14:00:00 (hora de verano de Europa central)
No válido después de	domingo, 22 de octubre de 2028, 14:00:00 (hora de verano de Europa central)
Información de la clave pública	
Algoritmo	Encriptación RSA (1.2.840.113549.1.1.1)
Parámetros	Ninguno
Clave pública	256 bytes: B6 E0 2F C2 24 06 C8 6D ...
Exponente	65537
Tamaño de la clave	2048 bits
Uso de la clave	Encriptar, Verificar, Derivar
Firma	256 bytes: 18 8A 95 89 03 E6 6D DF ...



*.www.instagram.com

Emitido por: DigiCert SHA2 High Assurance Server CA
Caduca: lunes, 5 de mayo de 2025, 1:59:59 (hora de verano de Europa central)
Este certificado es válido

- Confiar
- Detalles

Nombre del sujeto	
País o región	US
Región/Provincia	California
Localidad	Menlo Park
Empresa	Meta Platforms, Inc.
Nombre común	*.www.instagram.com
Nombre del emisor	
País o región	US
Empresa	DigiCert Inc
Unidad organizativa	www.digicert.com
Nombre común	DigiCert SHA2 High Assurance Server CA
Número de serie	01 AC 31 26 FF FE 8D A4 E6 D3 2B 1B 24 ED 28 8C
Versión	3
Algoritmo de firma	SHA-256 con encriptación RSA (1.2.840.113549.1.1.11)
Parámetros	Ninguno
No válido antes de	lunes, 3 de febrero de 2025, 1:00:00 (hora estándar de Europa central)
No válido después de	lunes, 5 de mayo de 2025, 1:59:59 (hora de verano de Europa central)
Información de la clave pública	
Algoritmo	Encriptación RSA (1.2.840.113549.1.1.1)
Parámetros	Ninguno
Clave pública	256 bytes: C0 B6 FD 46 36 BA 07 38 ...
Exponente	65537
Tamaño de la clave	2048 bits
Uso de la clave	Encriptar, Verificar, Ajustar, Derivar
Firma	256 bytes: 34 E3 2F C3 25 5E 48 35 ...